

CE/CZ4055 Cyber Physical System Security

Micro-Architectural Security

Anupam Chattopadhyay
CCDS, NTU



Go to wooclap.com

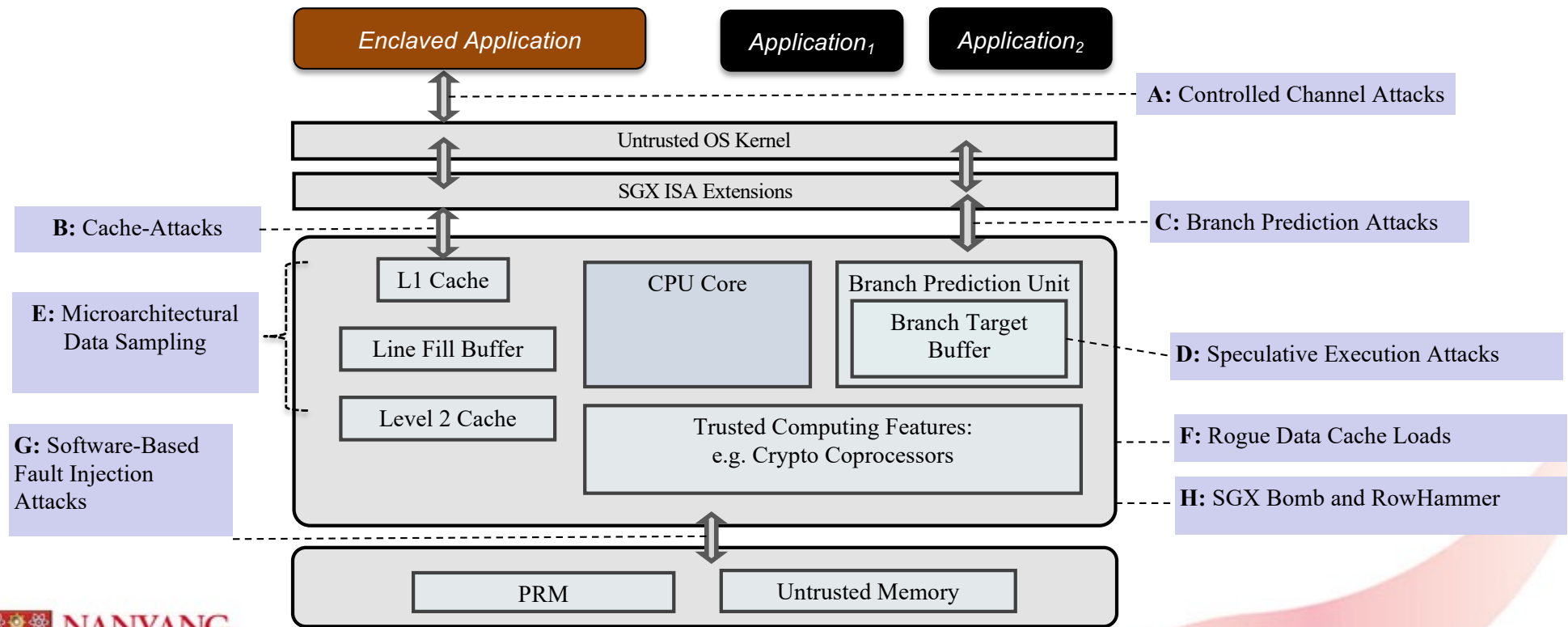
Enter the event code in the top banner

Event code

OHJYZY

Micro-architectural Attack Landscape

- **Software-level** Attacks, e.g., Return Address Pointer modification
- **Hardware-level** Attacks, e.g., Power-analysis Attacks
- **Hybrid** Attacks, e.g., PACMAN attack



Contents

→ Side Channel Attacks

- Timing Attack
- Power Attack
- Attacks on 'Secure' Processor
- Discussion



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY



Side Channel Attacks Classification

- **Passive Attacks:**

- Observe the target such as computer
- Gain the “additional” information leaked from the physical devices caused by any operation i.e. timing information, power consumptions, electromagnetic leaks, voices/sounds



- **Active Attacks:**

- Add “additional” inputs
- Change the environment or target itself to let abnormal operations or change the program flow, i.e. add voltage, clock glitching, or tempest virus



SCA: Real World Examples

- **KEELOQ**
 - Keyless Car Entry
 - Successful CPA in 10 traces
 - Manufacturer's key extracted
- **MiFARE DESFire (NXP)**
 - Access Card/Public Transport with HW 3-DES
 - Successful CPA in 250K traces
 - Allows Cloning
 - NXP discontinued
- **Virtex-II Pro (Xilinx)**
 - FPGA with HW 3-DES for bitstream encryption
 - Successful CPA in 25K traces
 - Allows Cloning/ Bitstream Modification
- **ProASIC (Actel)**
 - FPGA with HW AES for bitstream encryption
 - Successful attack in 0.01s
 - Allows Cloning/ Bitstream Modification



Security Attacks Classification

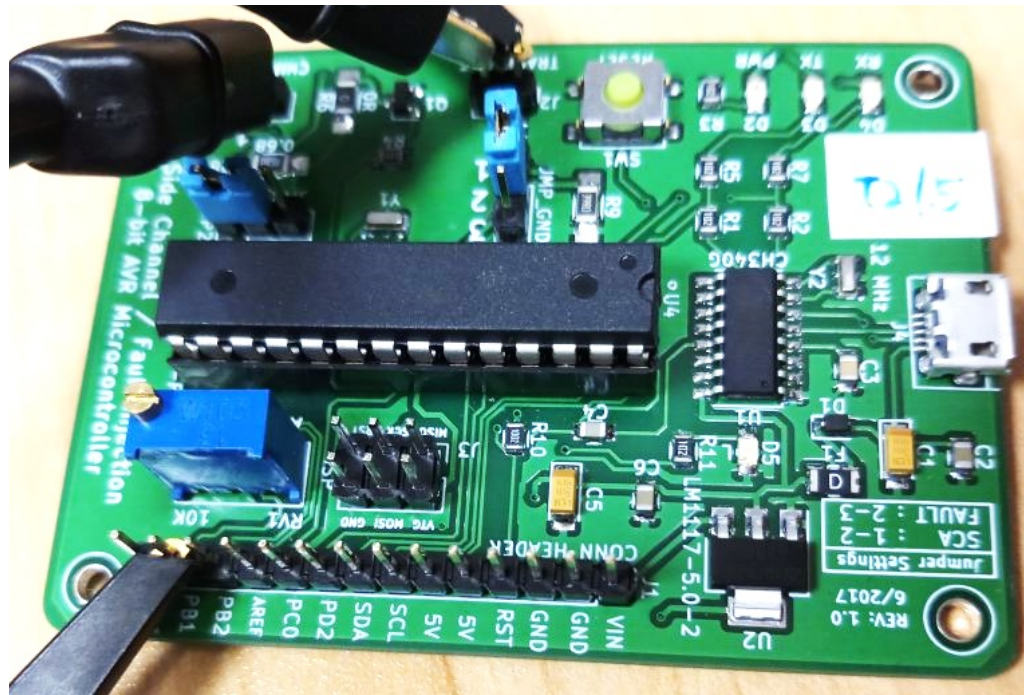
- **Passive Attacks**
- Active Attacks



Threat: Timing Attack

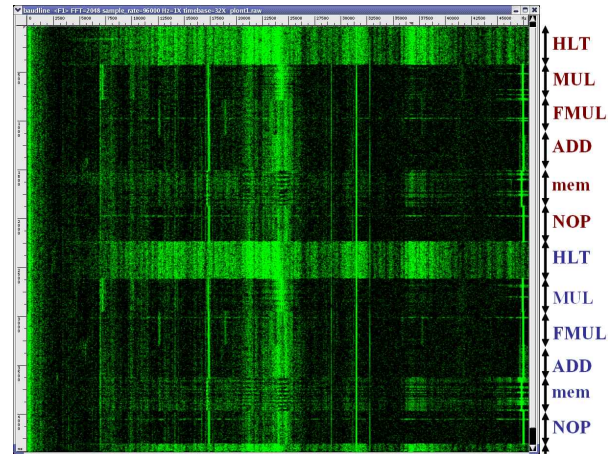
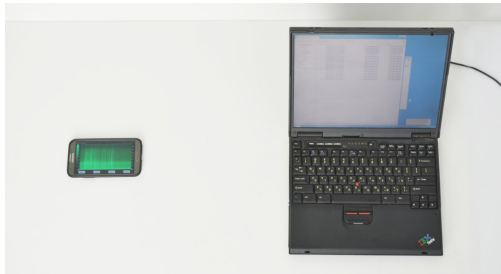
- Timing attack is an example of an attack that exploits the implementation rather than the algorithm itself
- Measure the time it takes for a certain unit to perform an operation
- Keep the input, output, and consumed time
- Check the correlation between time measurements of guess key or input and empirical result (often statistically)

Threat: Power Analysis Attack



Setup: CZ/E4055 Labs

Threat: Acoustic Cryptanalysis



- Recovered RSA keys from audio signals
- Importance of 'hardened' Root-of-Trust

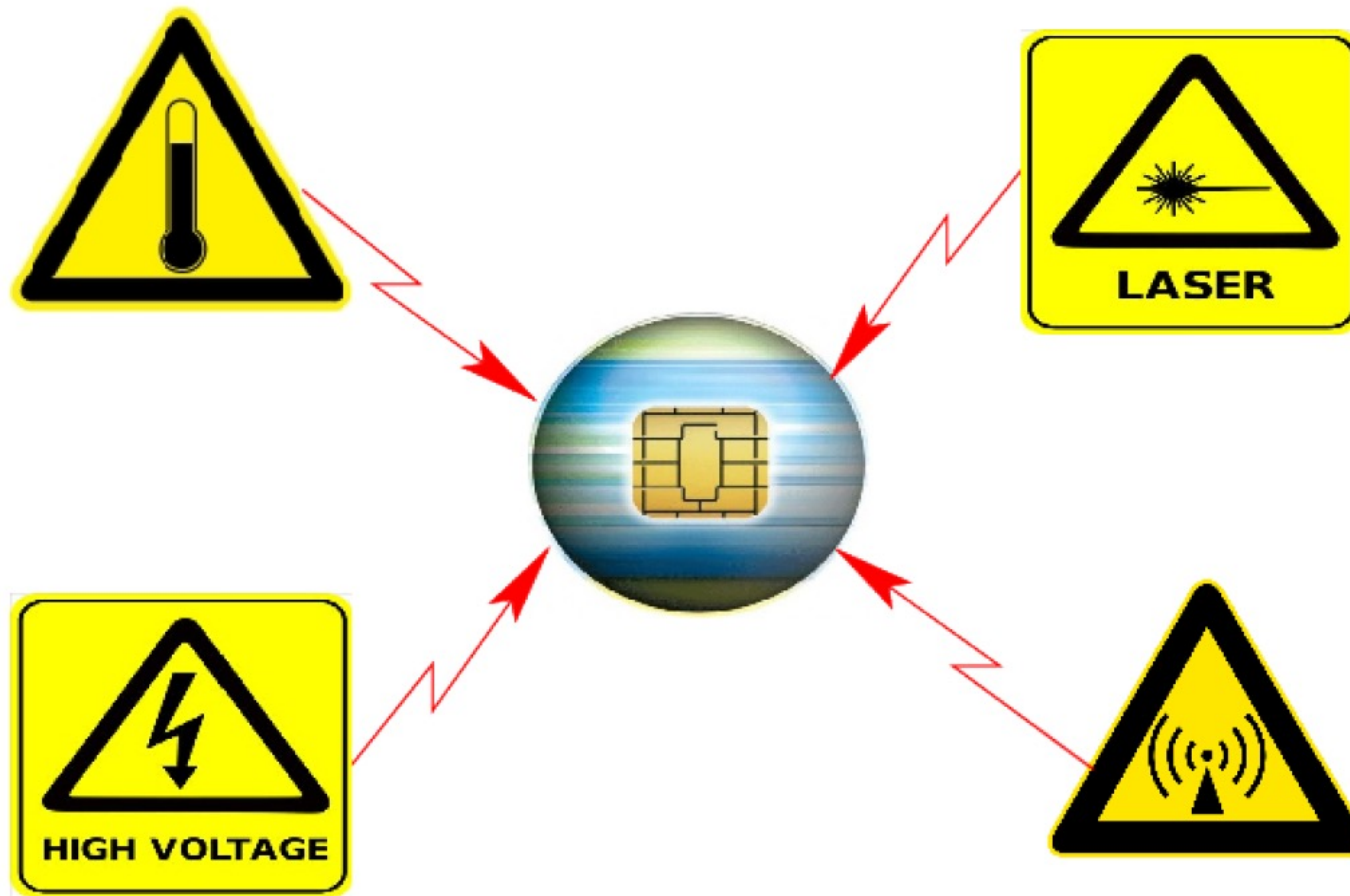
D. Genkin, A. Shamir and E. Tromer, "RSA Key Extraction via Low-Bandwidth Acoustic Cryptanalysis"
<http://www.cs.tau.ac.il/~tromer/acoustic/>

Security Attacks Classification

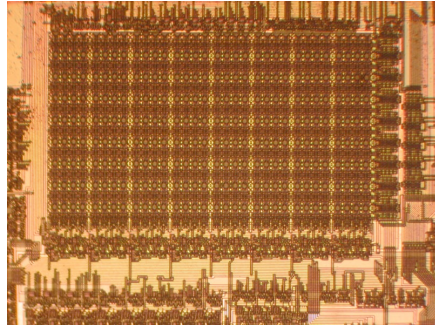
- Passive Attacks
- **Active Attacks**



Threat: Fault Injection Attacks (FIA)



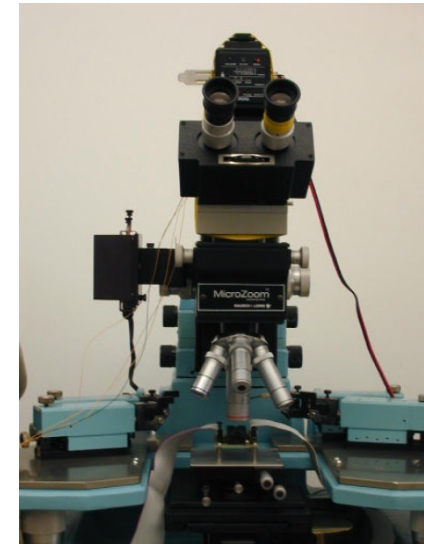
Example: Physical Attack (Fault)



80X

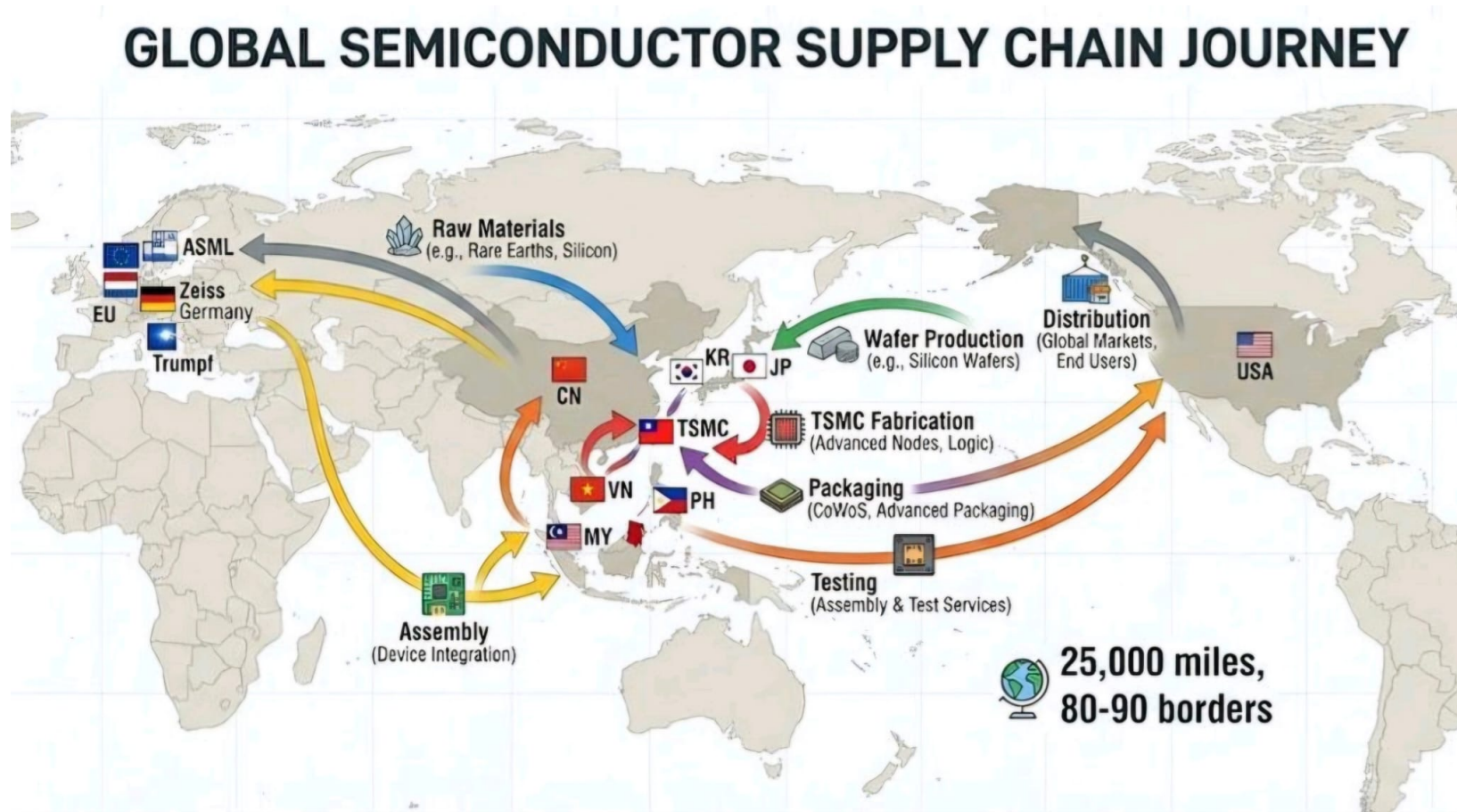


1500X

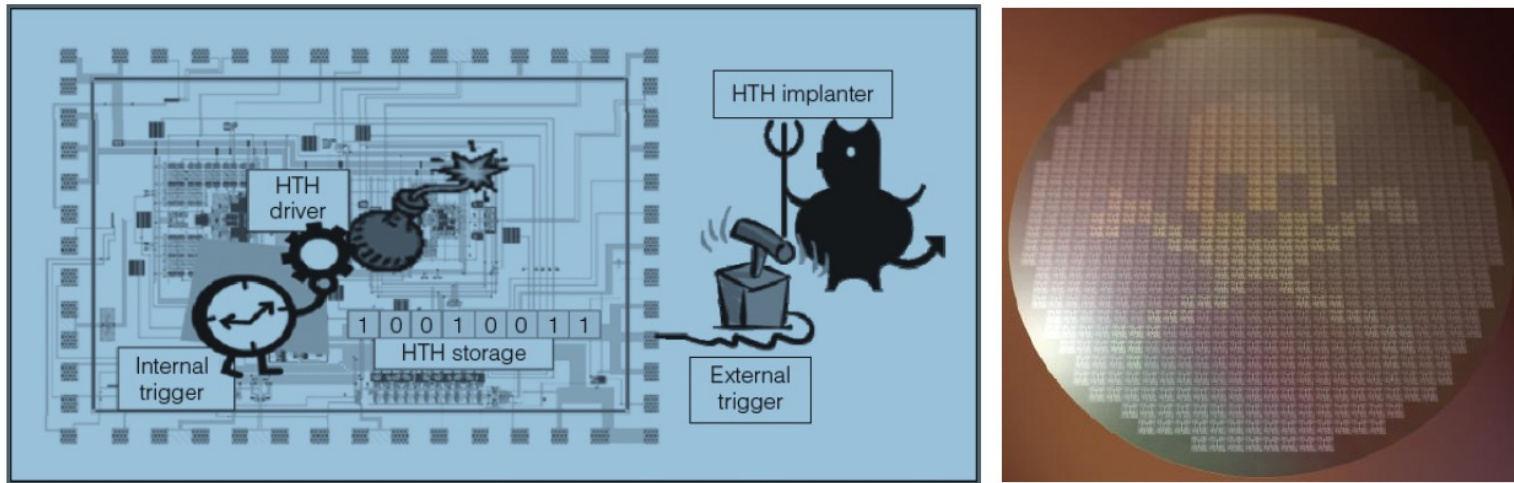


- With cheap laboratory equipment, memory states can be altered or damaged permanently
- Attack precision improves with sophisticated equipment
- Other forms of attack rely on the mode of information storage
 - e.g., magnetic storage can be attacked with strong magnetic field

Context: Hardware Trojan Horse (HTH)



Example: Hardware Trojan Horse (HTH)



- Malicious modifications in Integrated Circuits (ICs).
- Realize malicious functions (Leakage of sensible information, alteration of IC behaviours, etc.).
- HTH was born because of outsourcing design/fabrication process.

HTH Detection is difficult

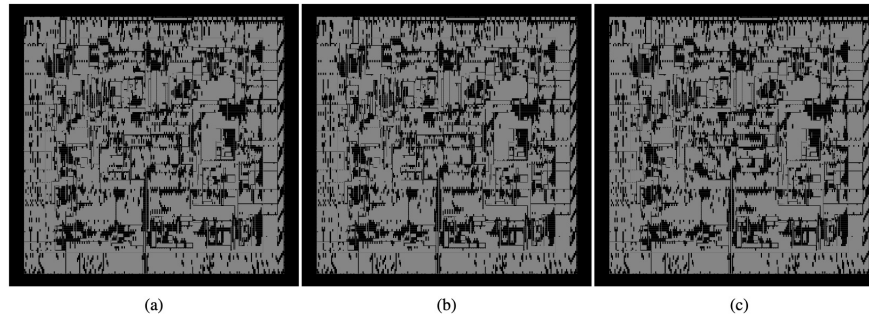


Figure 6. 6th metal layer AES layouts ($1200\ \mu\text{m} \times 1200\ \mu\text{m}$) with 50% core utilization rate for (a) Original AES, (b) AES with 1 AND gate HTH, (c) AES with 128 AND gate HTH

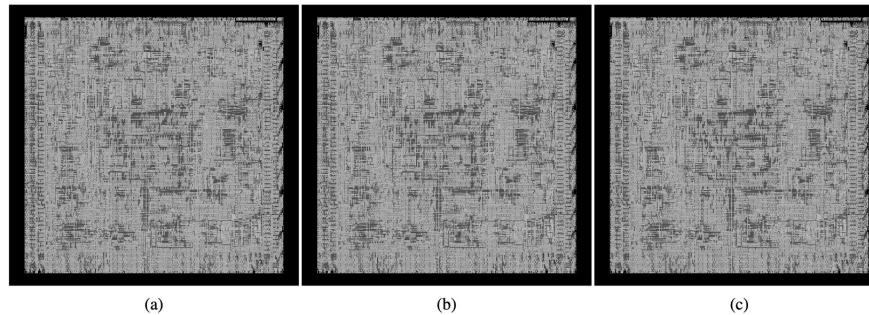


Figure 7. AES layouts ($1200\ \mu\text{m} \times 1200\ \mu\text{m}$) with 50% core utilization rate for (a) Original AES, (b) AES with 1 AND gate HTH, (c) AES with 128 AND gate HTH

S. Bhasin et al, "Hardware Trojan Horses in Cryptographic IP Cores", IEEE FDTC 2013

Wooclap Time



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY



Contents

- Side Channel Attacks

➔ *Timing Attack*

- Power Attack
- Attacks on 'Secure' Processor
- Discussion



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY



RSA Revisit

- **Encryption** (with public key): $C = M^e$
- **Decryption** (with private key): $M = C^d$
- $C^d \equiv (M^e)^d \equiv M^{ed} \equiv M^{1+h\varphi(n)} \equiv M \pmod{n}$
- We have $ed \equiv 1 \pmod{\varphi(n)}$. Hence we can write $ed = h(p-1)(q-1) + 1$ for some (non negative) integer h
- Now, $(M^e)^d = M^{ed} = M^{ed-1}M = M^{h(p-1)(q-1)}M = (M^{p-1})^{h(q-1)}M$.
- Fermat's Little Theorem $\rightarrow M^{p-1} \equiv 1 \pmod{p}$
- $(M^e)^d = \dots \equiv 1^{h(q-1)}M \pmod{p} = M \pmod{p}$
- $(M^e)^d = \dots \equiv 1^{h(p-1)}M \pmod{q} = M \pmod{q}$
- $\rightarrow (M^e)^d = M \pmod{pq} = M \pmod{n}$ [Euler's Lemma]

Modular Exponentiation

- The way of attacks depend on the details of modular exponentiation
- For efficiency, modular exponentiation is done via:
 - Simple multiplication
 - Repeated squaring
 - Chinese Remainder Theorem (CRT)
 - Montgomery multiplication
 - Sliding window
 - Karatsuba multiplication



Simple Multiplication

- The simplest case, the modular exponentiation is done by multiplying the number as many as the values of exponent such as
 - $2^{13} = 2 \times 2 \times 2 \times 2 \times 2 \times 2 \times \dots$
- Therefore, the execution time is directly proportional to the exponent value (key value)

Simple Multiplication: Attack

- An attacker eavesdrops the decryption operation, where (s)he gets *a plaintext* and *its computation time* (the decryption key is 13 which is hidden from the attacker)
- Attacker guesses the key is 12, decrypts with the guess key and it returns ***smaller*** computation time
- Then, attacker guesses the key is 14 and returned computation time is ***greater*** than empirical data
→ the key is between 12 and 14

Prevention: Constant Time Calculation

- In this strategy, the time it takes to do any operation must be independent from input and key (constant and equal at every time)
- Thus, every operation takes the slowest operational time by waiting
- However, this strategy raises the execution time dramatically (corresponding to the worst case)

Prevention: Random Time Calculation

- In this strategy, the time it takes to do any operation changes every operation at each time
- It is done by waiting a random time before starting the next operation
- However, this strategy also increases the execution time and its random variance must be large



Wooclap Time



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY



Contents

- Side Channel Attacks
- Timing Attack

→ *Power Attack*

- Attacks on 'Secure' Processor
- Discussion



Go to wooclap.com

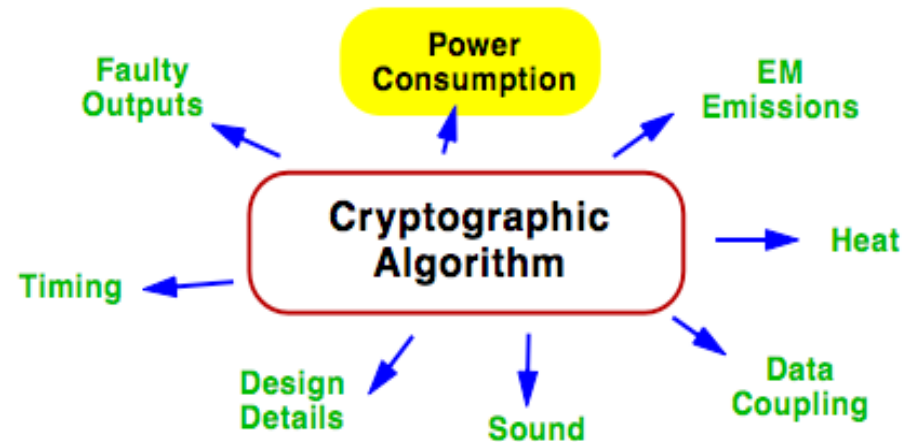
Enter the event code in the top banner

Event code

OHJYZY



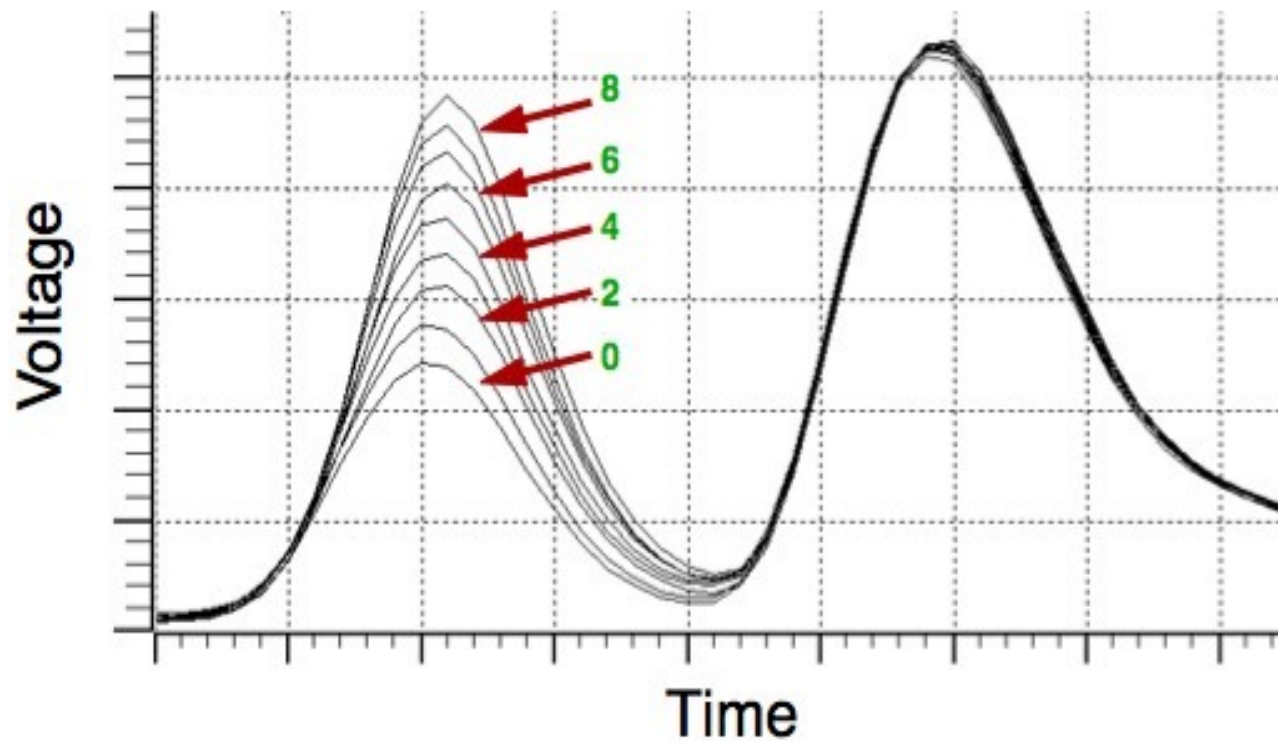
Side Channels



- Kocher et al., June 1998: Measure instantaneous power consumption of a device while it runs a cryptographic algorithm
- Different power consumption when operating on logical ones vs. logical zeroes.

Information Leakage

Hamming Weight or Hamming Distance Leakage



Systems under Threat

- Implementations of Cryptographic Algorithms
 - On smart cards
 - On general/specific purpose hardware
 - On software



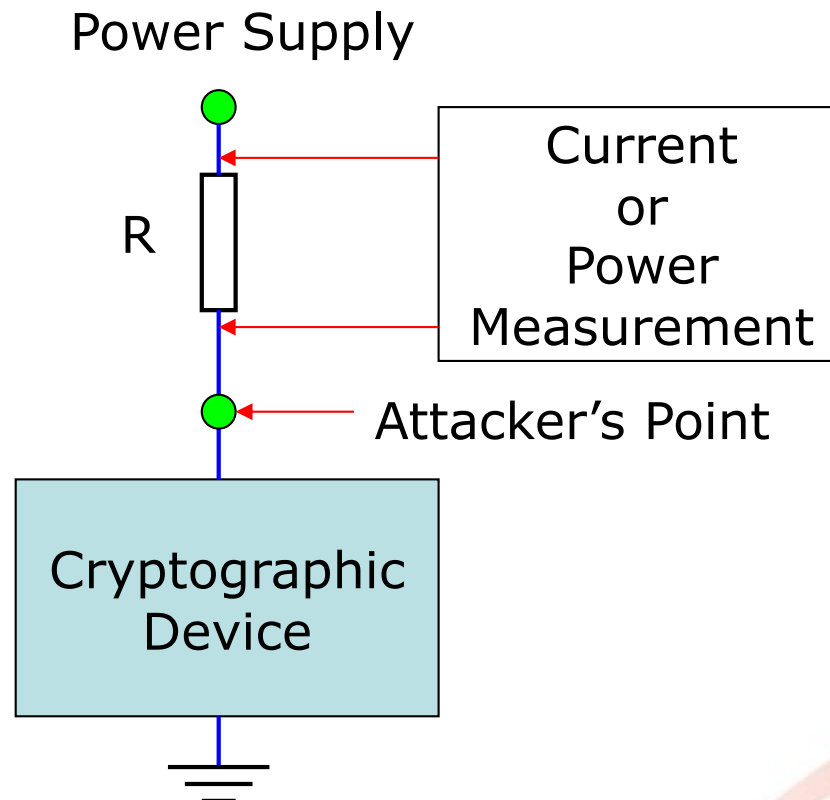
Power Attacks

- **Power Attacks are powerful and generic**
 - Based on statistical processing of observed data
 - Known random messages
 - Targeting a known algorithm
 - Running on a single smart card
- **Attack performed in 2 steps**
 - Acquisition phase: on-line with the smart card
 - Analysis phase: off-line on a server (hypothesis testing)

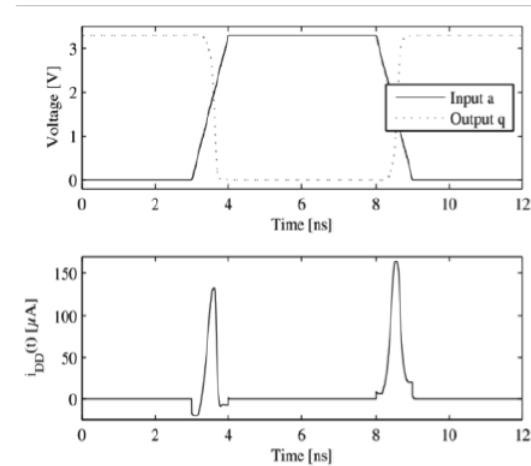
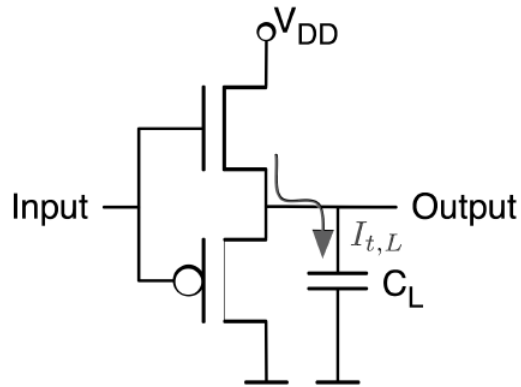


What is a Power Analysis Attack?

Side-channel attacks exploit correlation between secret parameters and variations in timing, power consumption, and other emanations from cryptographic devices to reveal secret keys

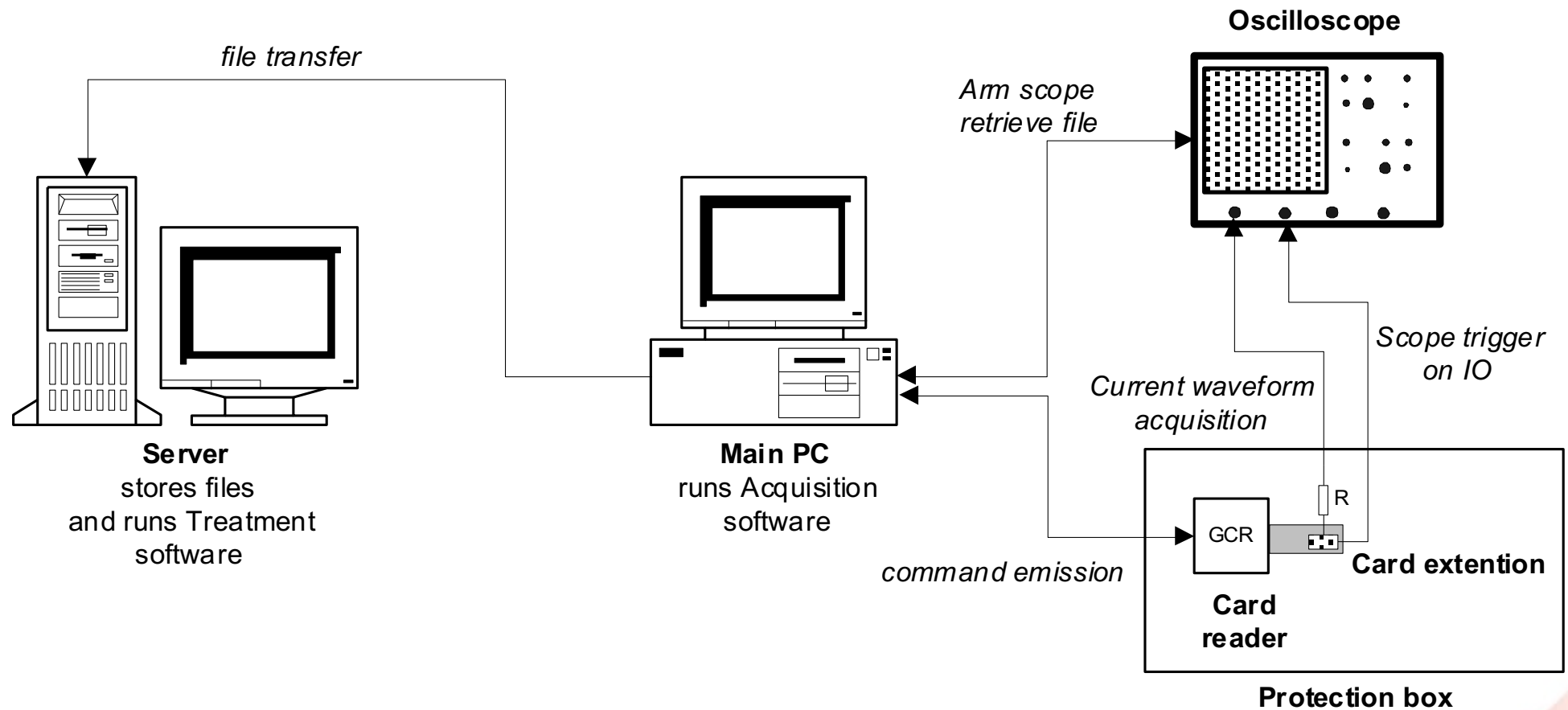


Why does Power Analysis Attack work?



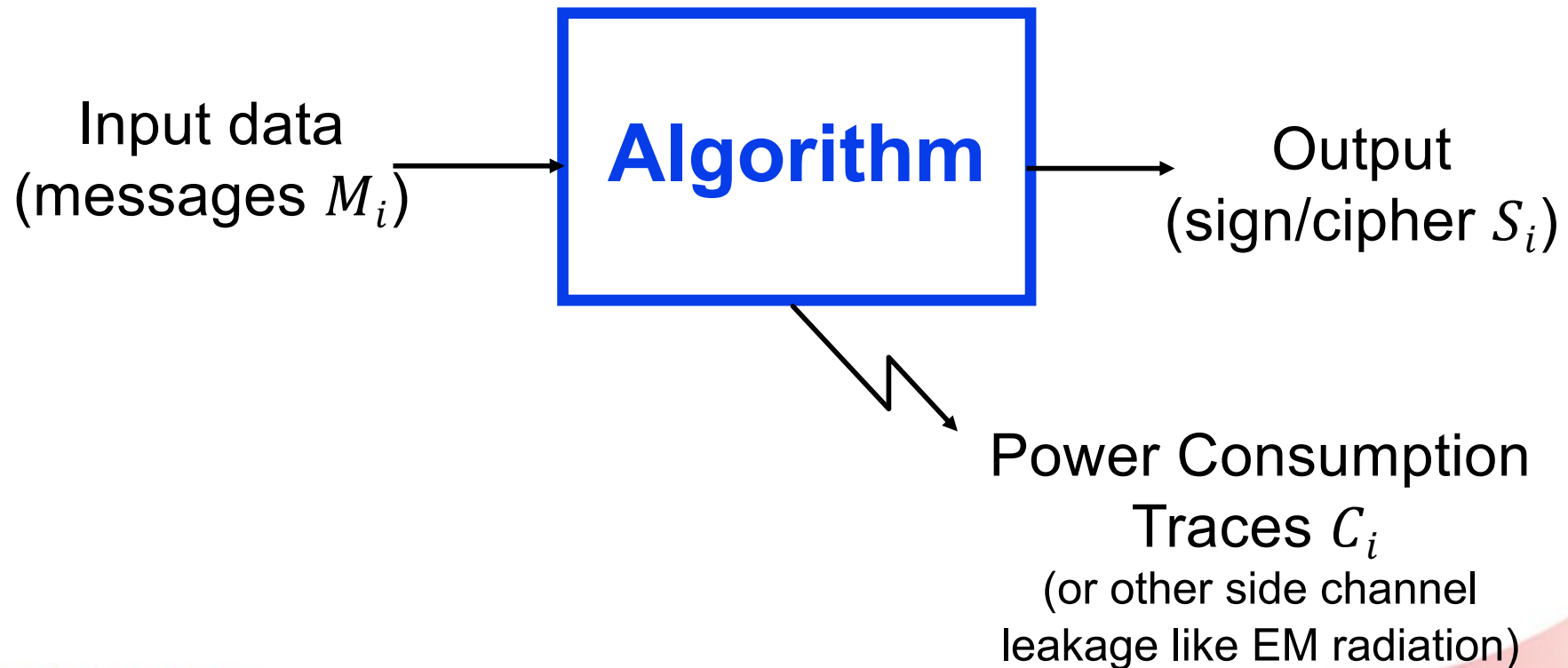
- CMOS cell is building block of almost every electronic system
- CMOS consumes power when input transition occurs
- This transition is observable through side-channels
- Thus the secret data processed by CMOS gate is observable

Acquisition Procedure



Acquisition Procedure

Play the algorithm N times



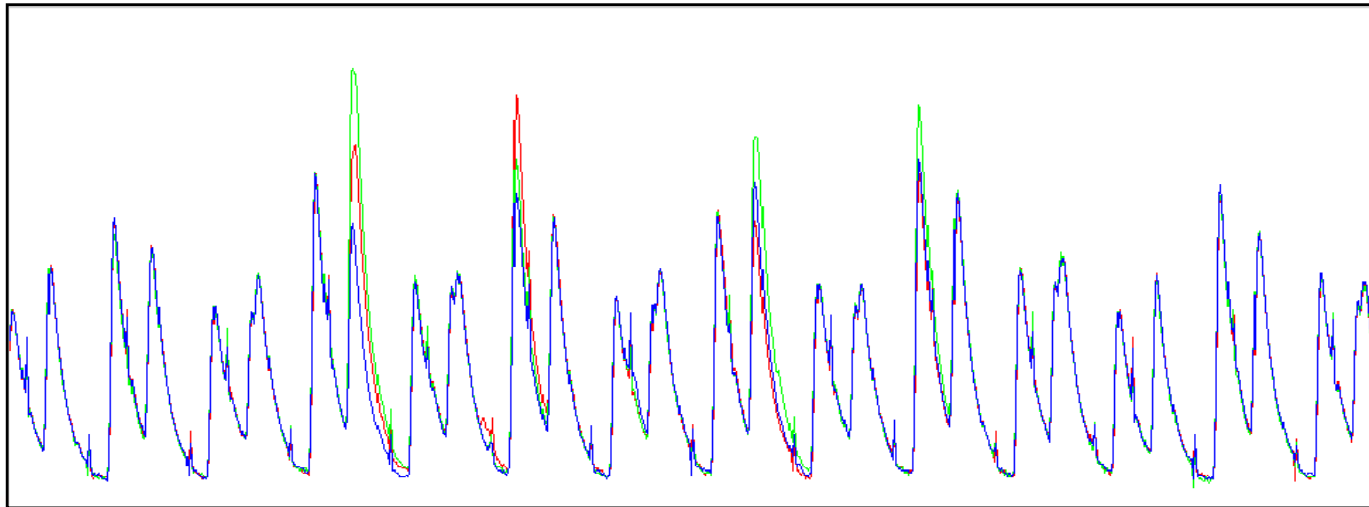
Acquisition Procedure

- After data collection, what is available ?

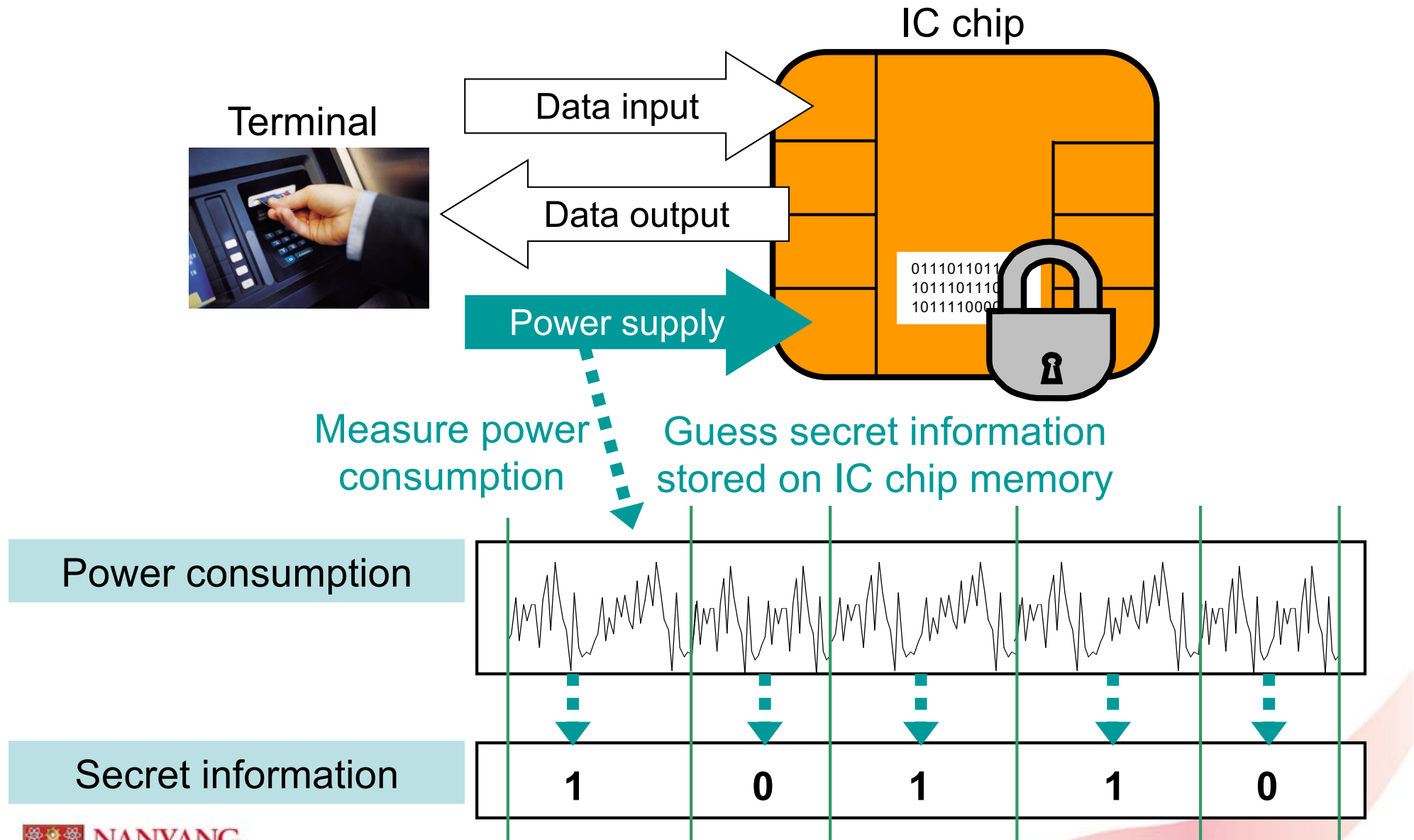
- N plain and/or cipher random texts

00	B688EE57BB63E03E
01	185D04D77509F36F
02	C031A0392DC881E6 ...

- N corresponding power consumption waveforms

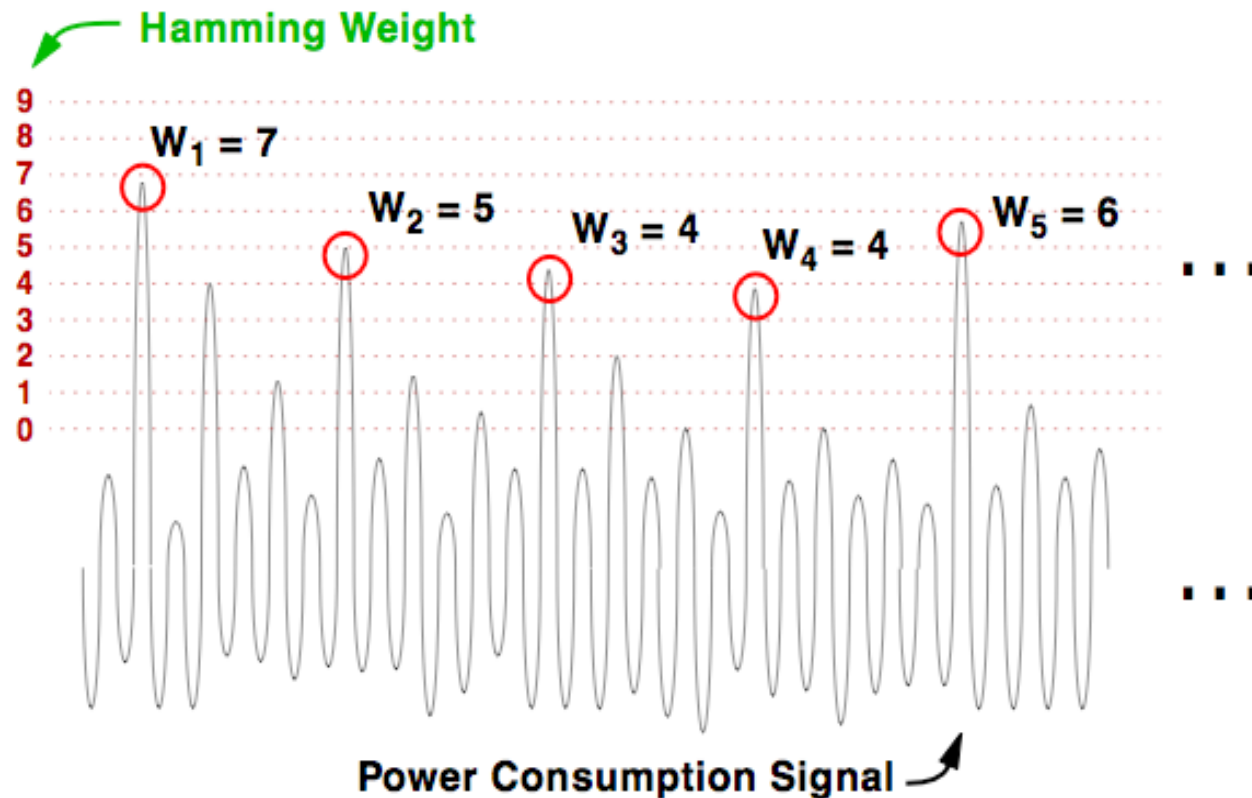


Simple Power Analysis



Simple Power Analysis

- Simple attack, needs a few seconds
- Direct observation of a system's power consumption
- Can gain very useful information



Simple Power Analysis (SPA)

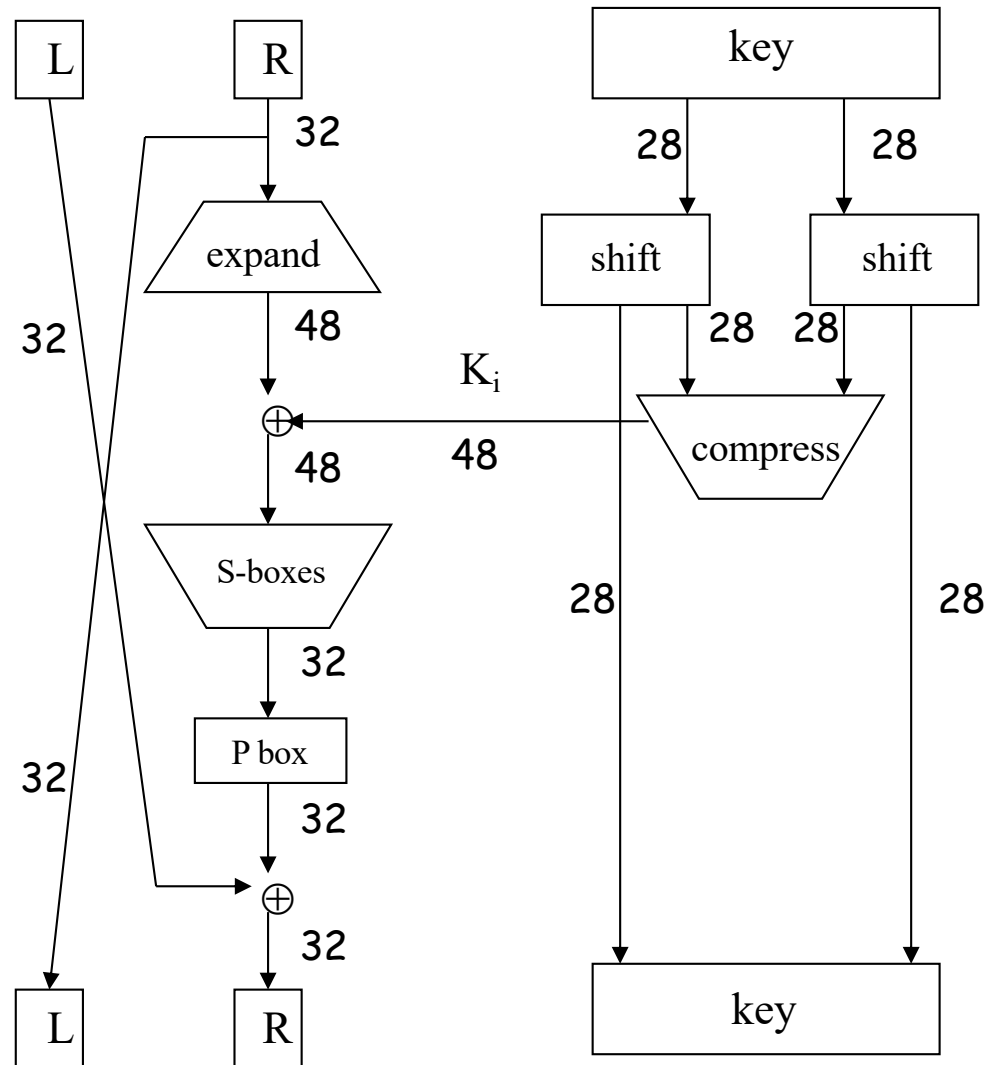
- Directly interprets the power consumption of the device
- Looks for the operations taking place and also the **key**!
- **Trace**: A set of power consumptions across a cryptographic process
- 1 millisecond operation sampled at 5MHz yield a trace with 5000 points



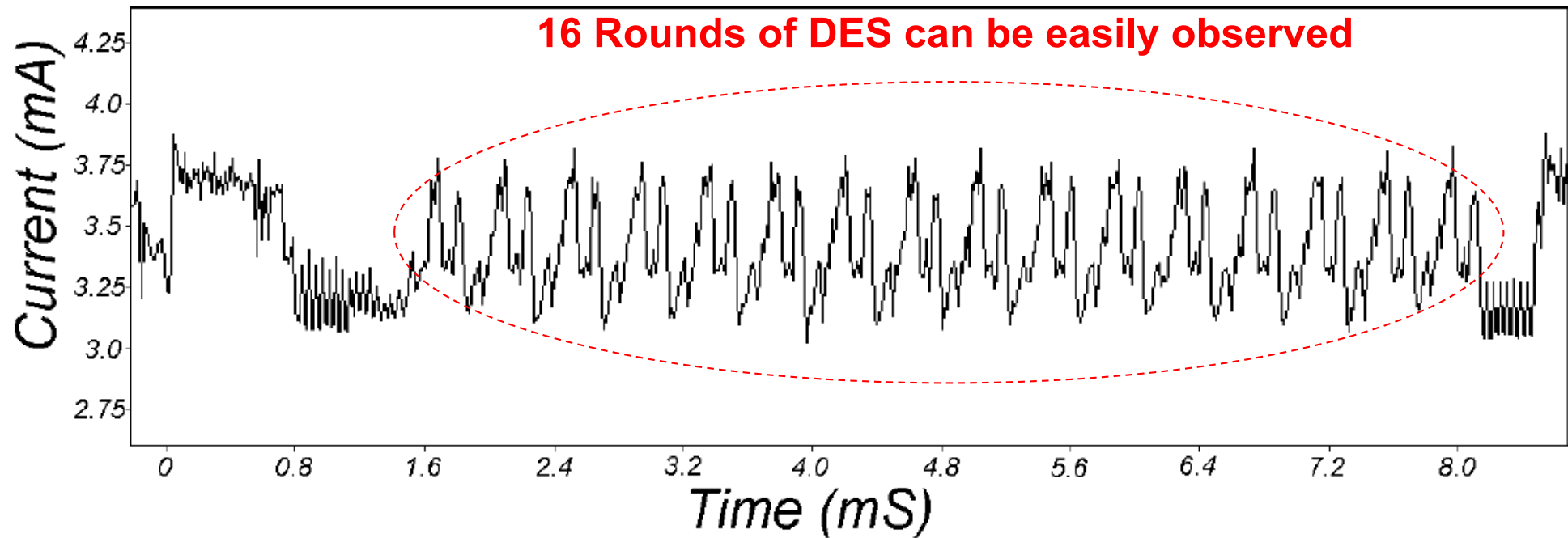
Example: DES

- DES is a block cipher
- 64 bit block length
- 56 bit key length
- 16 rounds
- 48 bits of key used each round (subkey)
- Each round is simple (for a block cipher)
- Security depends primarily on “S-boxes”

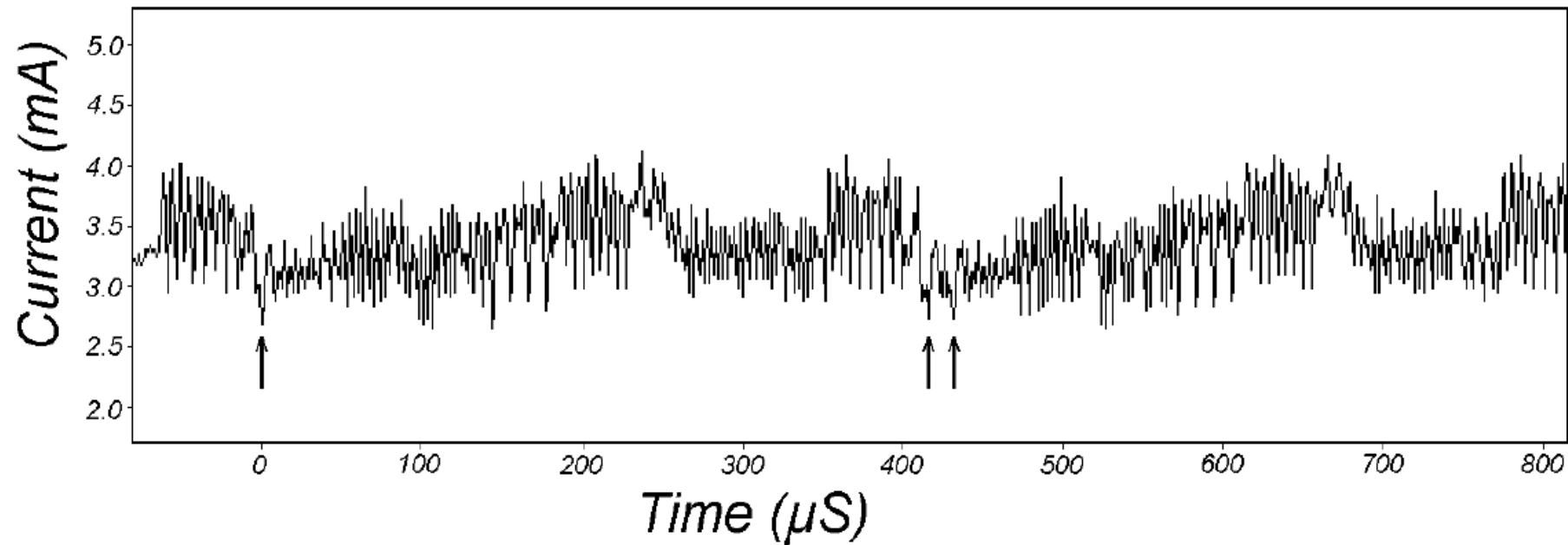
DES Round Operation



Power Traces of DES



Power Traces for DES



The 28 bit key registers C and D are rotated once in round 2, while twice in round 3. These **conditional branches** depending on the key bits leak critical information.

Wooclap Time



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY



Contents

- Side Channel Attacks
- Timing Attack
- Power Attack

→ Attacks on 'Secure' Processor

- Discussion



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY



Cold Boot Attack

- Data is in DRAM for a few minutes after the power is cut-off
 - Can extend that duration by spraying liquid Nitrogen (-50°C)
- Useful for digital forensics
- Encryption Keys should be in TPM

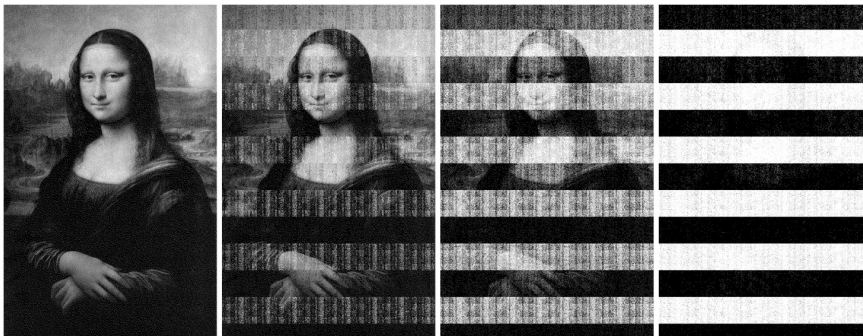
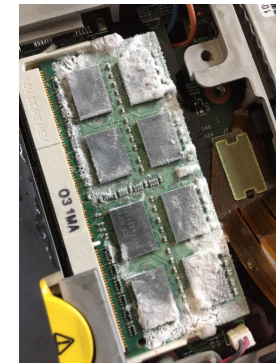


Figure 4: We loaded a bitmap image into memory on Machine A, then cut power for varying lengths of time. After 5 seconds (left), the image is indistinguishable from the original. It gradually becomes more degraded, as shown after 30 seconds, 60 seconds, and 5 minutes.

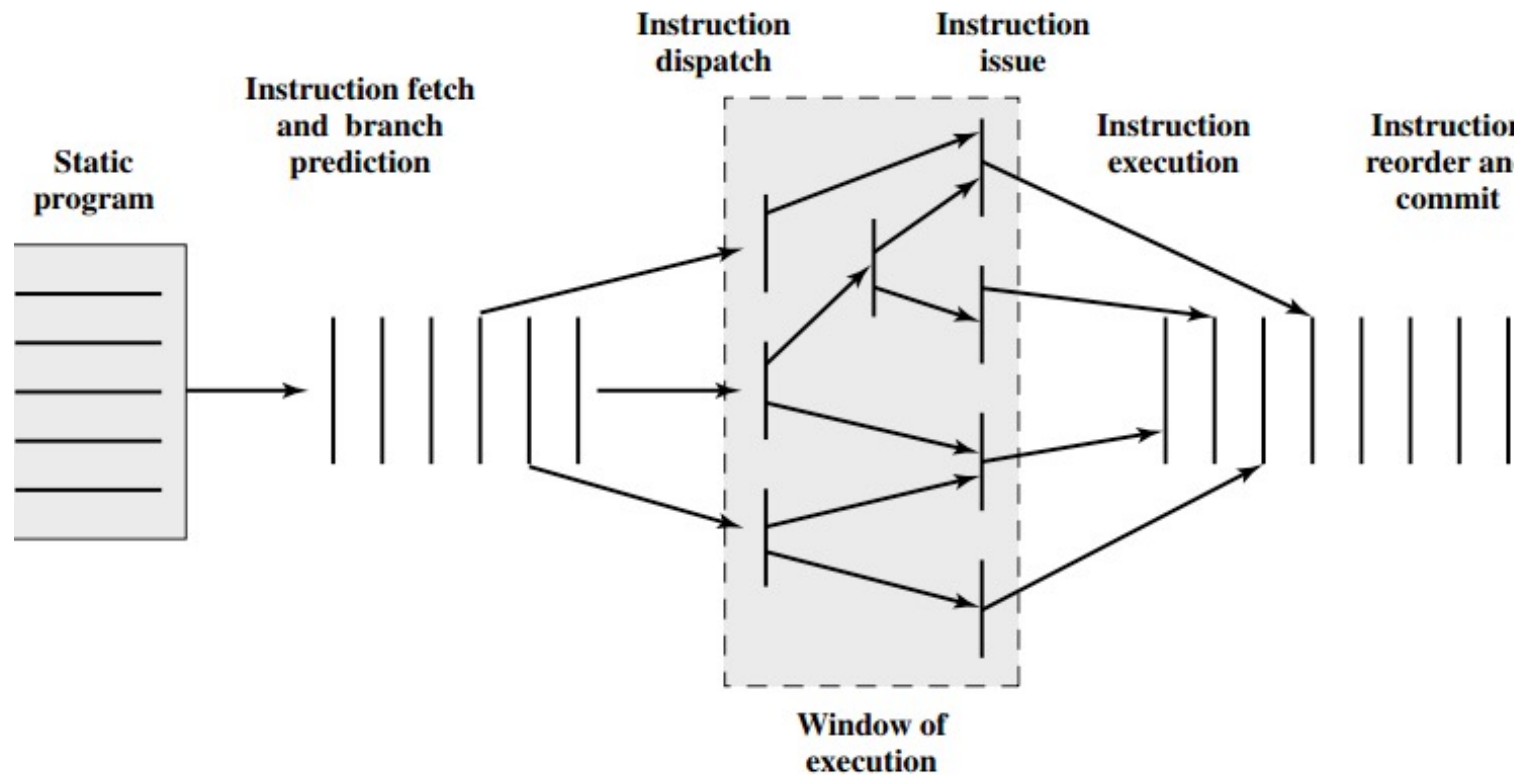


J. Alex Halderman et al, "Lest We Remember: Cold Boot Attacks on Encryption Keys", USENIX Security, 2008

Review: Pipeline Hazards

- Data hazards – read after write
 - Use data forwarding inside the pipeline
 - Do out-of-order execution for no dependency
- Control hazards – `beq, bne, j, jr, jal`
 - Stall – hurts performance
 - Predict – with even more hardware, can reduce the impact of control hazard stalls even further if the branch prediction (BHT) is correct and if the branched-to instruction is cached (BTB)

Superscalar Processor

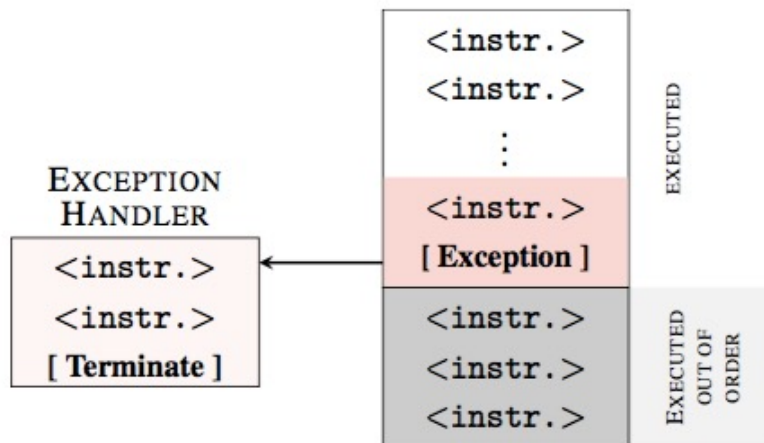


Meltdown Attack

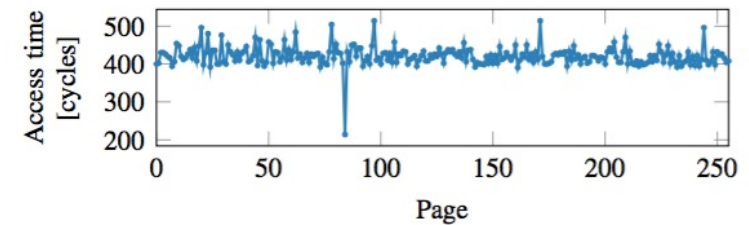
- Out-of-order execution is an indispensable performance feature and present in a wide range of modern processors.
- The attack is independent of the operating system, and it does not rely on any software vulnerabilities.
- Meltdown exploits side-channel information available on most modern processors,
 - e.g., modern Intel microarchitectures since 2010 and potentially on other CPUs of other vendors.

Meltdown Attack (*contd.*)

```
1 raise_exception();  
2 // the line below is never reached  
3 access(probe_array[data * 4096]);
```



OOO Execution



Data loaded into cache

Plundervolt Attack

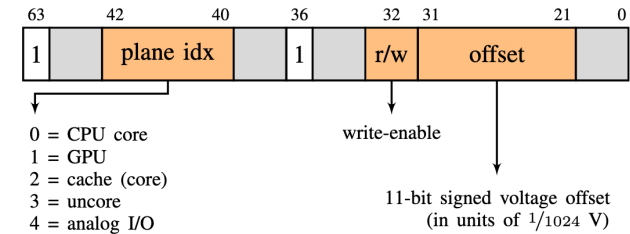
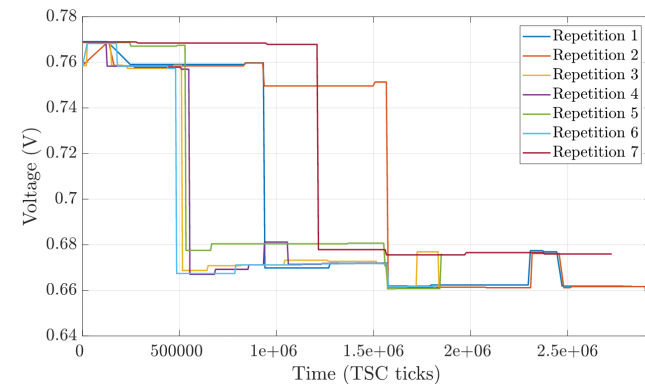
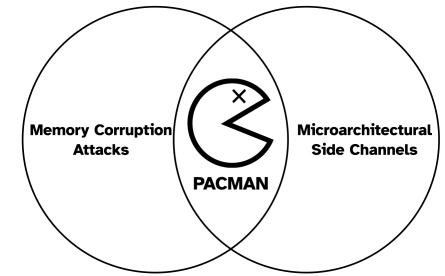


Fig. 1. Layout of the undocumented undervolting MSR with address 0x150.

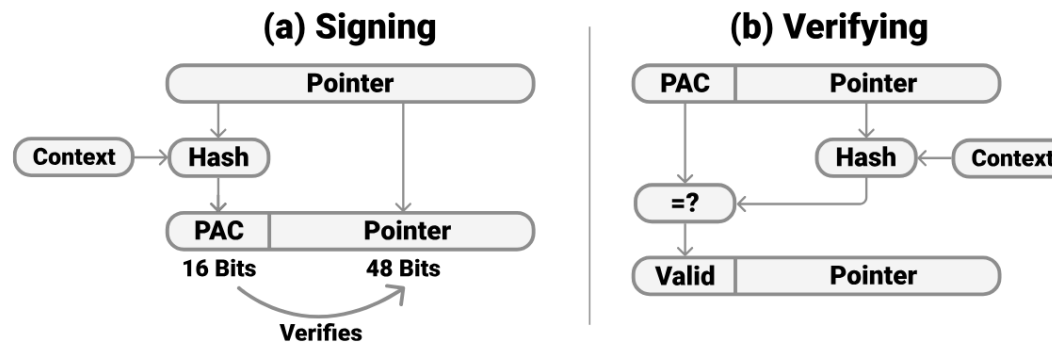
- Software-based fault injection flow
 - Undocumented Model-specific Register used for controlling voltage scaling
 - Voltage modification leads to slower execution and unfinished computations
- Can be controlled to mount attacks
 - OpenSSL signature corruption
 - RSA key recovery
 - Redirecting outside secure enclave



PACMAN Attack



- ARM uses **pointer authentication code (PAC)** by using cryptographic hash (Apple M1 uses 16-bit hash) to prevent attacks such as **return address pointer modification**.



- The hash could be brute-forced and checked through other side-channel leakages if it passed the PAC verification or not.
- Renders Apple M1 vulnerable to various attacks, including **Control Flow hijacking**.

Effects of these attacks

- Speculative Execution can be disabled
 - Up to 45% performance drop reported
- Can also be vulnerable for other speculative executions, e.g., branch prediction
- Intel SGX discontinued; new product line Trust Domain Extensions (TDX) introduced
- Fundamental trade-off between Security and Efficiency

Solution

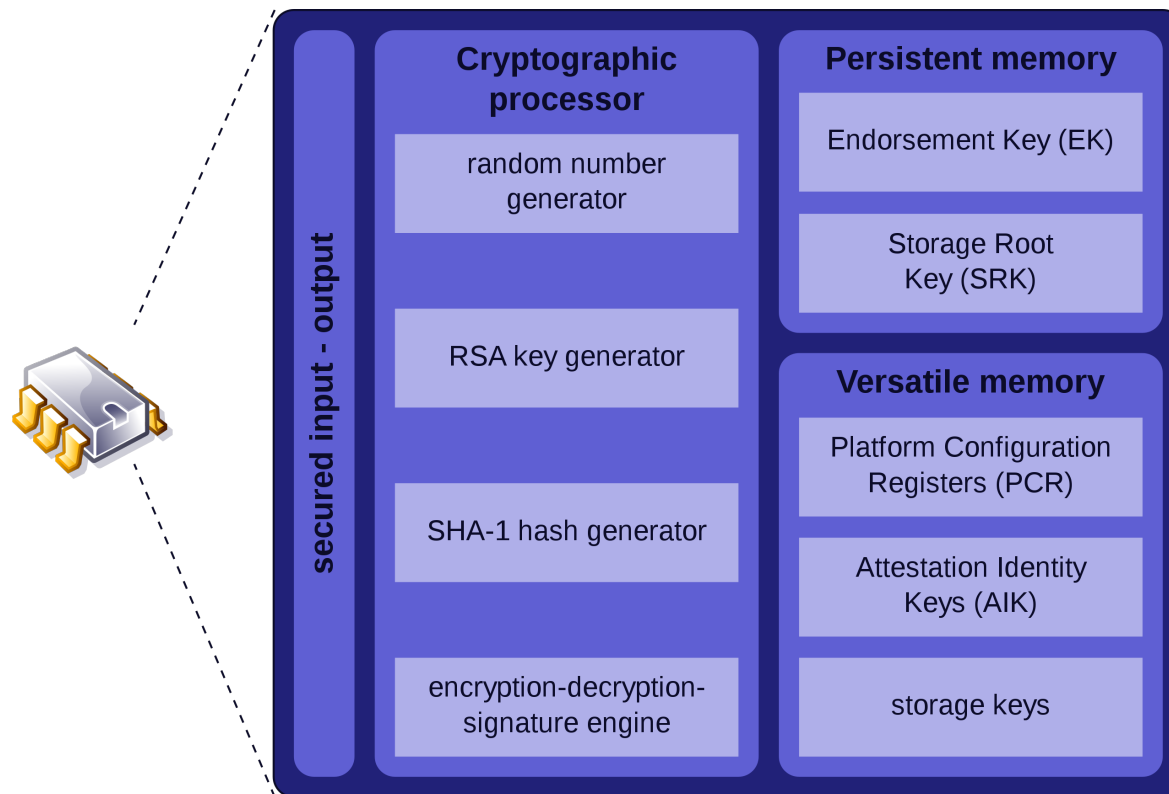
TRUSTED PLATFORM MODULE (TPM)

Trusted Platform Module (TPM)

- **Standard for secure crypto-processor**
 - ISO/IEC 11889, currently at TPM 2.0
 - Developed by Trusted Computing Group (TCG)
- **TPM guarantees the platform integrity**
- **TPM provides**
 - Root of Trust for software layers at higher abstraction
 - Modes of secure operation in a larger system, e.g., Trusted Execution Environment (TEE)
- **Foundational technology for HSM**



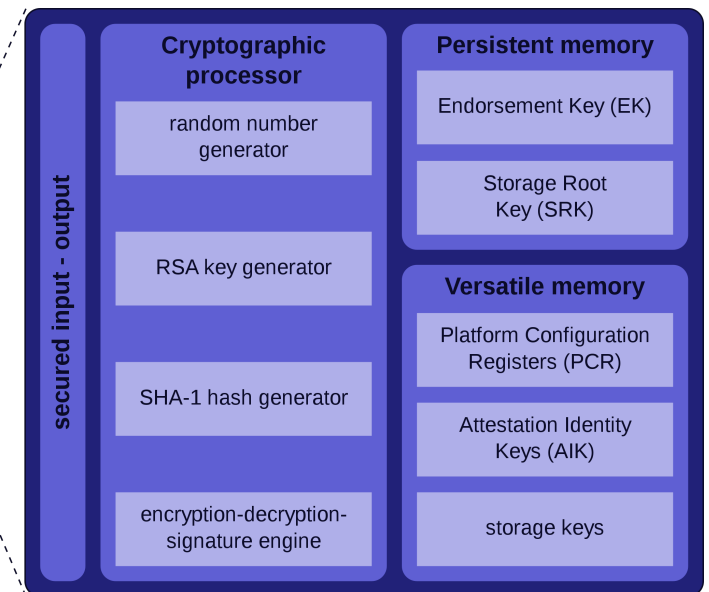
TPM Specification



TPM Specification Details

Persistent Memory

- Endorsement Key (EK)
 - Asymmetric private-public key pair unique to each TPM
 - X.509 format, certified by the manufacturer
- Storage Root Key (SRK)
 - Keys for a user, to establish ownership
 - Forms the root of *key hierarchy*
- Private EK and SRK *never leaves the TPM*

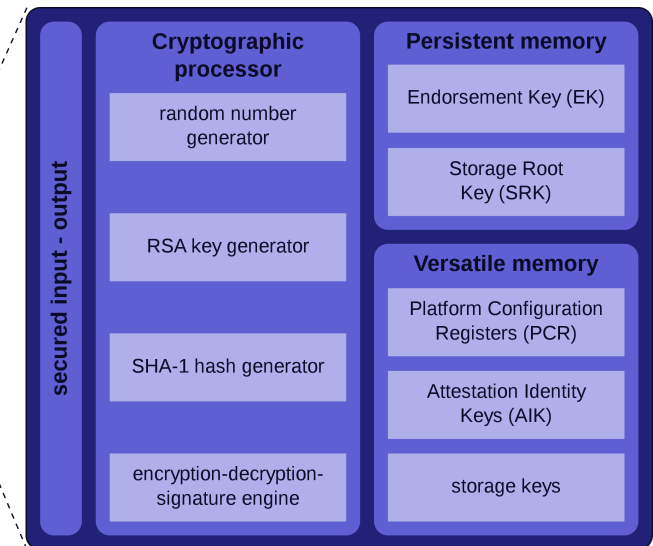


TPM Specification Details (contd.)

Versatile Memory

- **Storage Keys**
 - Used for encrypting/decrypting data
 - While leaving the TPM, keys are encrypted using Storage Root Key
- **Attestation Identity Keys**
 - Used for digital signature
 - Asymmetric key-pairs generated by the TPM
- **Platform configuration register**
 - Contains hash of updated values, e.g., log of attestation/boot processes.
 - *Example: during encryption PCR values are embedded. If decryption results do not match with the PCR, it is declared as a failure, i.e., someone modified the OS kernel to update PCRs*

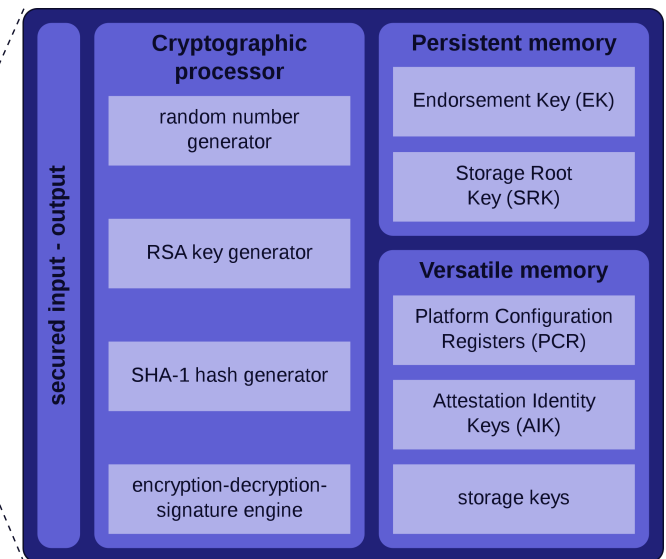
storage



TPM Specification Details (contd.)

Computing blocks

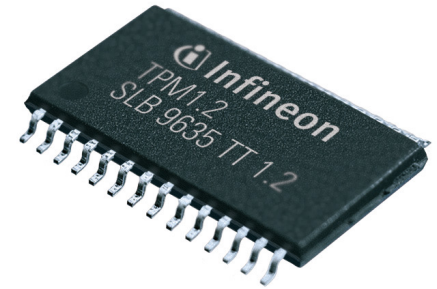
- Random number generator
- Asymmetric key-pair generator
- Hash (now migrating to SHA-2)^{1,2,3}
- Encryption/Decryption/Digital Signature



1. G. Leurent et al, "SHA-1 is a Shambles", Usenix 2020
2. A. Chattopadhyay et al, "On The Cost of ASIC Hardware Crackers: A SHA-1 Case Study", CT-RSA 2021
3. <https://shattered.io/>

TPM → HSM

- TPM is a specification
 - Can be implemented as a part of a system
 - Also manufactured as a TPM chip
 - Microarchitectures adopt TPM to build the Trusted Execution Environment (TEE)
- HSM is an implementation
 - Standalone device
 - Follows TPM specification
 - Integrable through system-level interfaces (PCI, USB, Ethernet)



HSM Implementation Certifications

- **FIPS Certification**

- **Level 1:** Includes basic security requirements (at least one approved algorithm or function must be used), allowing the software and firmware components of the cryptographic module to be executed on a general-purpose system using an untested operating system.
- **Level 2:** This level enhances level 1 security by requiring the use of mechanisms for *tamper-evidence detection and role-based authentication*.



HSM Implementation Certifications (contd.)

- **FIPS Certification**

- **Level 3:** This level requires additional requirements for *tamper-resistance, tamper-response, and identity-based authentication*. It also requires a logical separation between interfaces through which critical security parameters enter and exit the system. Private keys can only be imported or exported in encrypted form, e.g., *Thales Luna Network HSM*
- **Level 4:** This level includes advanced intrusion protection (*tamper-active*) and is designed for products operating in *physically unprotected environments*

- **Common Criteria Certification**

- More inclusive IT security and assurance evaluation



Wooclap Time



Go to wooclap.com

Enter the event code in the top banner

Event code

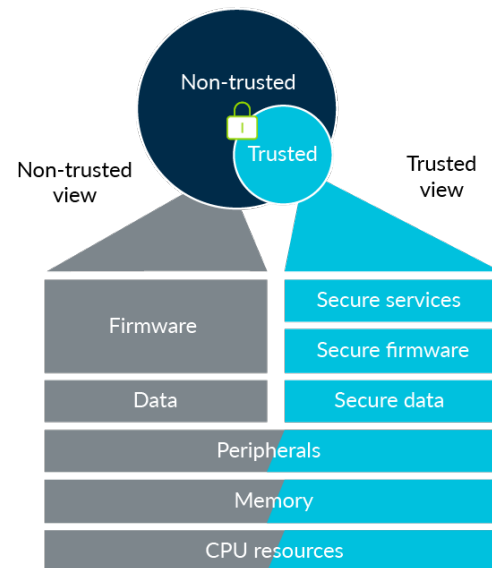
OHJYZY



Complementary Approach

- **Security Stack**

- Hardened Modules in Trusted Execution Environment (TEE)
- Firmware/Software maintaining protocols on higher design level



ARM TrustZone

Contents

- Side Channel Attacks
- Timing Attack
- Power Attack
- Attacks on 'Secure' Processor



Discussion



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY



What did we learn?

- What are typical micro-architectural attacks?

- *Active*
- *Passive*

- Timing Attack

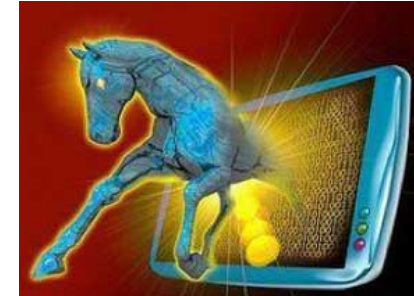
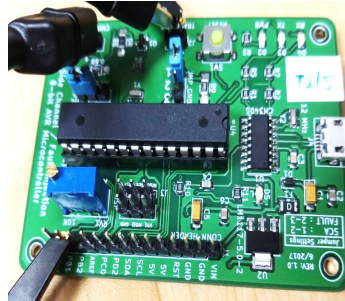
- *Cache access*

- Power Attack

- *Correlation of Power and Data*

- Recent Attacks

- *Discontinued Product Line*



MELTDOWN



The End



Go to wooclap.com

Enter the event code in the top banner

Event code

OHJYZY

